Wireless, IoT, and Cloud Security

Intro to Wireless Network

Basic communications system elements

- Source
- Destination
- Transmission Medium

Wired vs Wireless

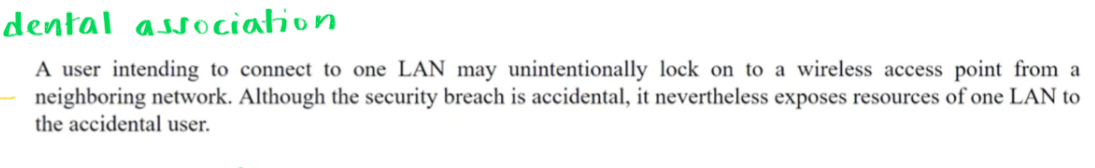
- Losses
- Mobility
- Security
- Bandwidth
- Cost

Wireless Security

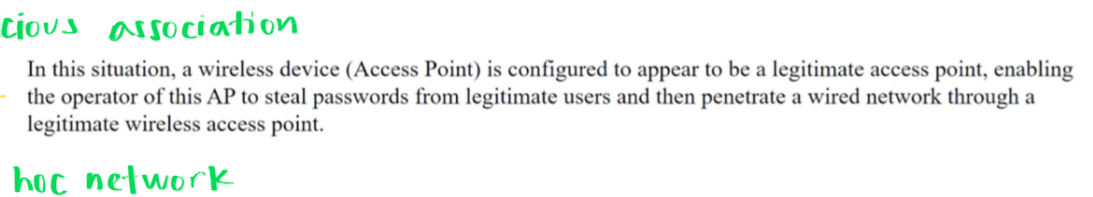
- channel
  - wireless nw typically involves broadcast communications
  - which is more susceptible to eavesdropping & jamming
  - also more vulnerable to active attacks
- mobility
  - wireless devices are more mobile & portable, resulting in a number of risks
- resources
  - some wireless devices, like smartphones, have complex OS
  - but limited memory & processing to counter threats
  - limited energy
- Accessibility
  - sensors & robots, may be left unattended in remote/hostile locations, ↑ vulnerability to physical attacks

Wireless Network Threats

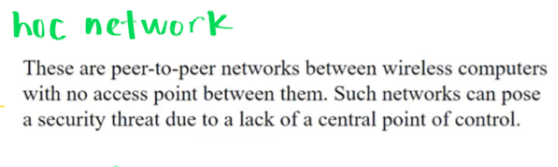
- Accidental association


A user intending to connect to one LAN may unintentionally lock on to a wireless access point from a neighboring network. Although the security breach is accidental, it nevertheless exposes resources of one LAN to the accidental user.

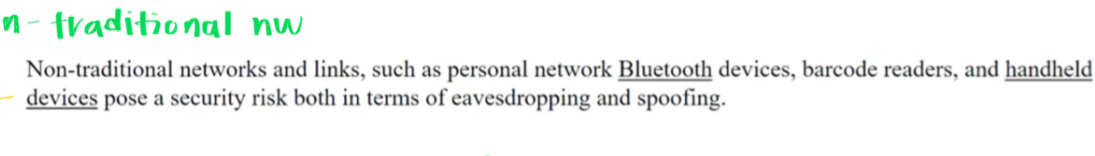
- Malicious association


In this situation, a wireless device (Access Point) is configured to appear to be a legitimate access point, enabling the operator of this AP to steal passwords from legitimate users and then penetrate a wired network through a legitimate wireless access point.

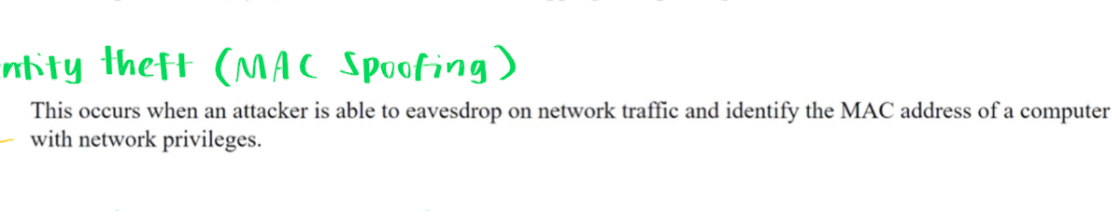
- Ad hoc network


These are peer-to-peer networks between wireless computers with no access point between them. Such networks can pose a security threat due to a lack of a central point of control.

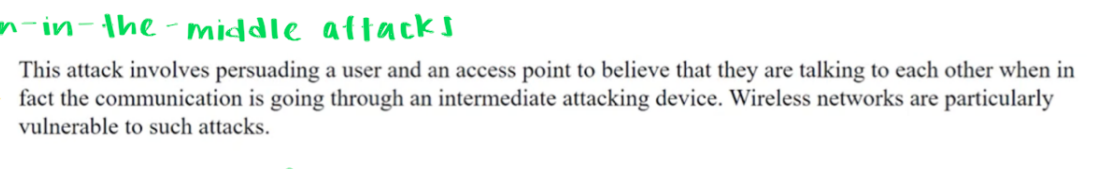
- Non-traditional nw


Non-traditional networks and links, such as personal network Bluetooth devices, barcode readers, and handheld devices pose a security risk both in terms of eavesdropping and spoofing.

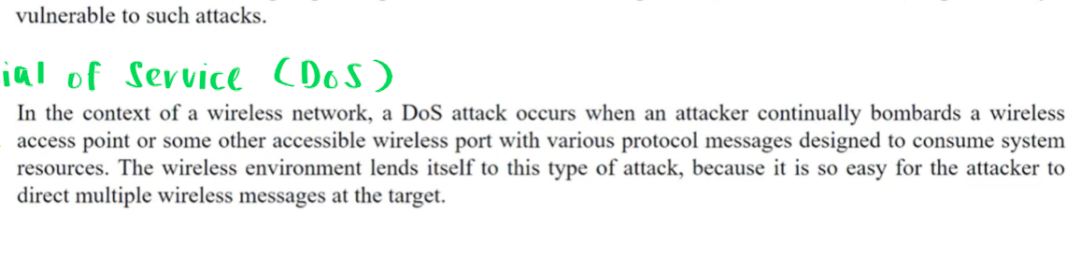
- Identity theft (MAC Spoofing)


This occurs when an attacker is able to eavesdrop on network traffic and identify the MAC address of a computer with network privileges.

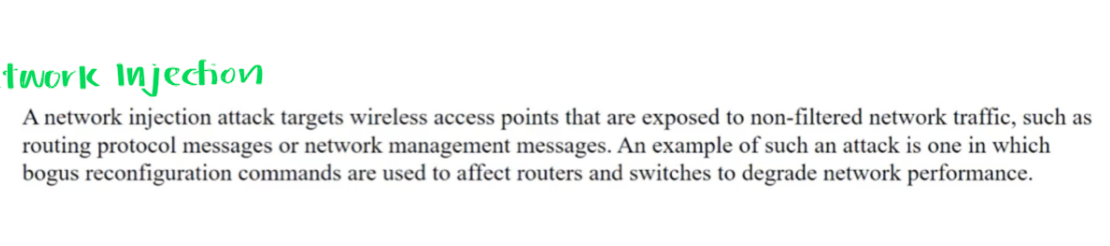
- Man-in-the-middle attacks


This attack involves persuading a user and an access point to believe that they are talking to each other when in fact the communication is going through an intermediate attacking device. Wireless networks are particularly vulnerable to such attacks.

- Denial of Service (DoS)


In the context of a wireless network, a DoS attack occurs when an attacker continually bombards a wireless access point or some other accessible wireless port with various protocol messages designed to consume system resources. The wireless environment lends itself to this type of attack, because it is so easy for the attacker to direct multiple wireless messages at the target.

- Network Injection


A network injection attack targets wireless access points that are exposed to non-filtered network traffic, such as routing protocol messages or network management messages. An example of such an attack is one in which bogus reconfiguration commands are used to affect routers and switches to degrade network performance.

Securing Wireless Networks

- Counter for eavesdropping
  - signal hiding techniques
  - encryption

Introduction to WiFi

WiFi History

- IEEE 802.11 standard
  - primarily concerned with Data Link & Physical Layers

WiFi Medium Access Control

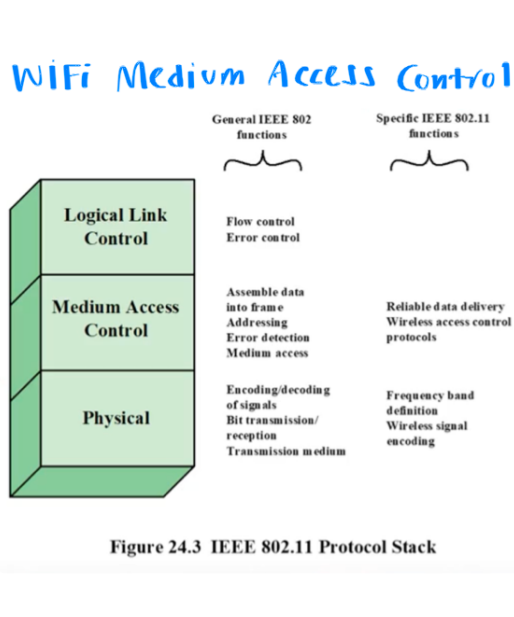
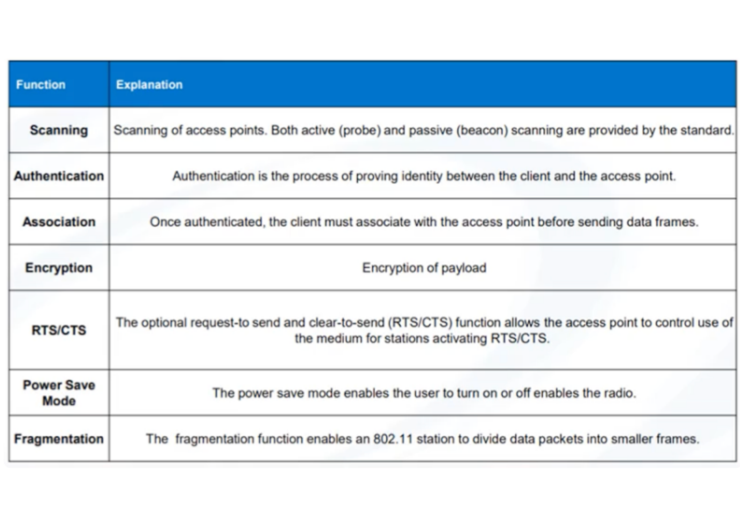


Figure 24.3 IEEE 802.11 Protocol Stack



Function	Explanation
Scanning	Scanning of access points. Both active (probe) and passive (beacon) scanning are provided by the standard.
Authentication	Authentication is the process of proving identity between the client and the access point.
Association	Once authenticated, the client must associate with the access point before sending data frames.
Encryption	Encryption of payload
RTS/CTS	The optional request-to-send and clear-to-send (RTS/CTS) function allows the access point to control use of the medium for stations activating RTS/CTS.
Power Save Mode	The power save mode enables the user to turn on or off enables the radio.
Fragmentation	The fragmentation function enables an 802.11 station to divide data packets into smaller frames.

Infrastructure

AP – client services:
- Authentication : open, shared key or WPS
- De-authentication
- Privacy : WEP, WPA or WPA2

Distribution System services:
- Association : maps the client into the distribution system via access point
- Disassociation : release of association
- Distribution : used to deliver MAC frames across the distribution system
- Integration : enables delivery of MAC frames between DS and non 802.11
- Re-association : transition of association from one access point to an other

Advantages & Disadvantages

- Freedom – work from any location where you get a signal
- Setup cost – no cabling
- flexibility – quick & easy setup in temp/permanent place
- scalable
- mobile access

- speed – slower than cable
- range – affected by medium (walls)
- security – unauthorized access
  - compromise data
  - denial of service

Basic Security Strategies

- block your Service Set Identifier (SSID) from being broadcast
- change default name
- change default pass
- center in building/house

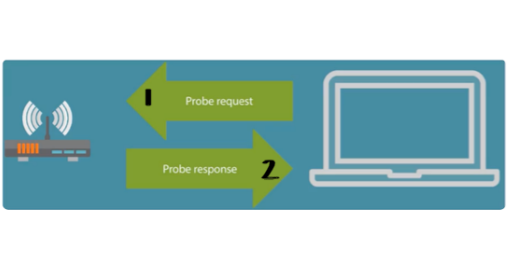
Media Access Control (MAC) Filtering

- every device has unique MAC address
  - allocated by manufacturer
- MAC filtering only allows certain addresses access
- mostly for home use
  - tedious to implement in large scale

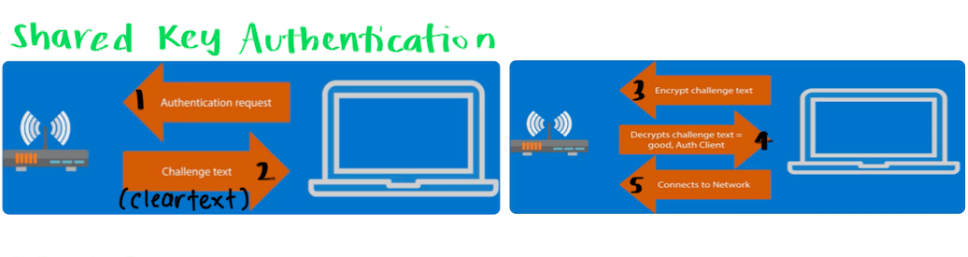
WiFi Authentication (Part 1)

WiFi Authentication Modes

- Open System Authentication



- Shared Key Authentication



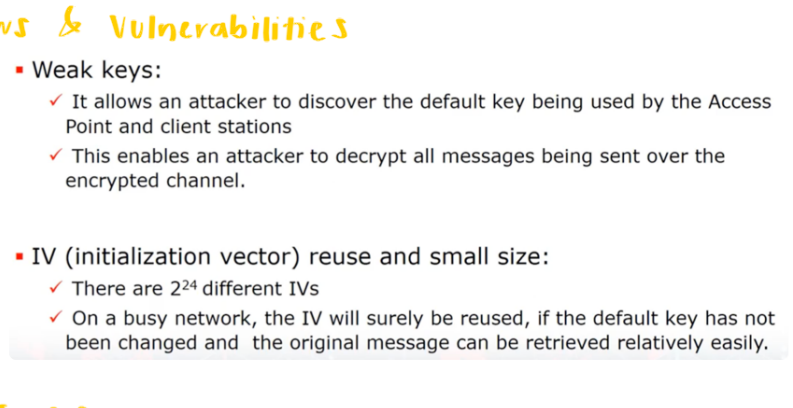
- IEEE 802.1x

WiFi Encryption

- Wired Equivalent Privacy (WEP)
- WiFi Protected Access (WPA)
- WiFi Protected Access (WPA2)

WEP, WPA & WPA2

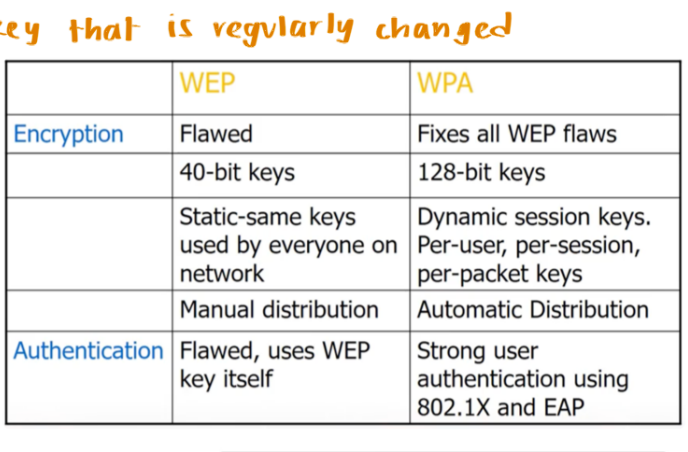
- WEP
  - uses RC4 stream cipher ; pseudo random bytes
  - 2 versions : 64 bit & 128 bit
  - Flaws & Vulnerabilities



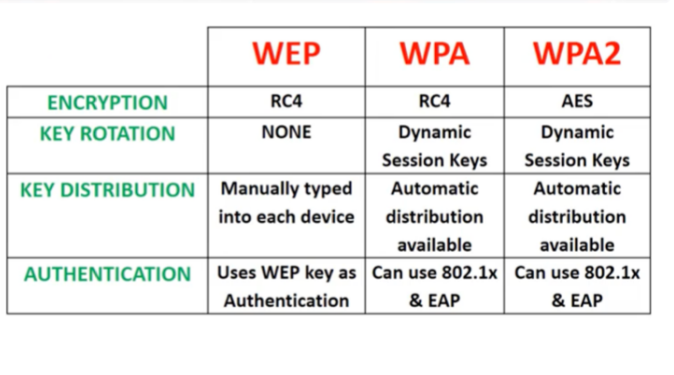
- Weak keys:
  - ✓ It allows an attacker to discover the default key being used by the Access Point and client stations
  - ✓ This enables an attacker to decrypt all messages being sent over the encrypted channel.
- IV (initialization vector) reuse and small size:
  - ✓ There are 2^{24} different IVs
  - ✓ On a busy network, the IV will surely be reused, if the default key has not been changed and the original message can be retrieved relatively easily.

  - Attacks
    - Can be cracked in seconds, goal is to collect enough IVs to be able to crack the key
- WPA
  - new standard that uses 40 or 104 bit WEP key, but also changes the key on each packet
  - 128 bit Temporal Key Integrity Protocol (TKIP) encryption
    - uses a master key that is regularly changed
- WPA2
  - uses block cipher
  - designed to replace WEP with 128 bit AES
  - immune against :

- ✓Man-in-the middle
- ✓Authentication forging
- ✓Replay
- ✓Key collision
- ✓Weak keys
- ✓Packet forging
- ✓Dictionary attacks



	WEP	WPA
Encryption	Flawed	Fixes all WEP flaws
	40-bit keys	128-bit keys
	Static-same keys used by everyone on network	Dynamic session keys. Per-user, per-session, per-packet keys
	Manual distribution	Automatic Distribution
Authentication	Flawed, uses WEP key itself	Strong user authentication using 802.1X and EAP



	WEP	WPA	WPA2
ENCRYPTION	RC4	RC4	AES
KEY ROTATION	NONE	Dynamic Session Keys	Dynamic Session Keys
KEY DISTRIBUTION	Manually typed into each device	Automatic distribution available	Automatic distribution available
AUTHENTICATION	Uses WEP key as Authentication	Can use 802.1x & EAP	Can use 802.1x & EAP

Procedures to improve Wireless Security

- use Wireless IPS (WIPS)
- use WPA2 where possible
- change SSID often
- use good + long passphrase
- AES more secure, use TKIP for speed
- use/upgrade nw to latest security

WiFi Authentication (Part 2)

Authentication using IEEE 802.1x (Secure network authentication)

- same as Iowa State, we connect, sent to browser to further authenticate
- layer 2 (MAC layer) auth
- how auth takes place
  - client req access to AP
  - AP asks for creds
  - client sends creds to AP which forwards to RADIUS for Auth

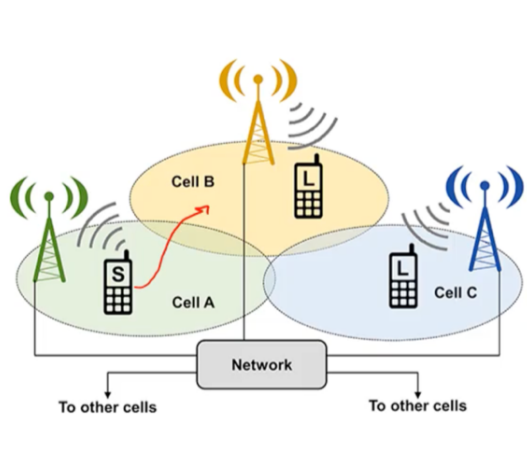
+ no overhead

− some EAPs ; no mutual auth

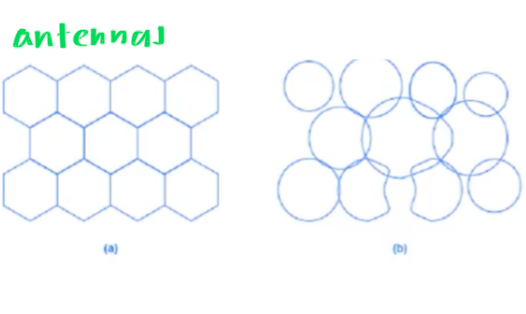
- Extensible Auth Prot (EAP)
  - used for Point-to-Point (PPP)
  - developers can create their own methods for creds
  - many options ; OTP, certificates, smartcards

Cellular Networks (Part 1)

Intro



most cell towers use omnidirectional antennas

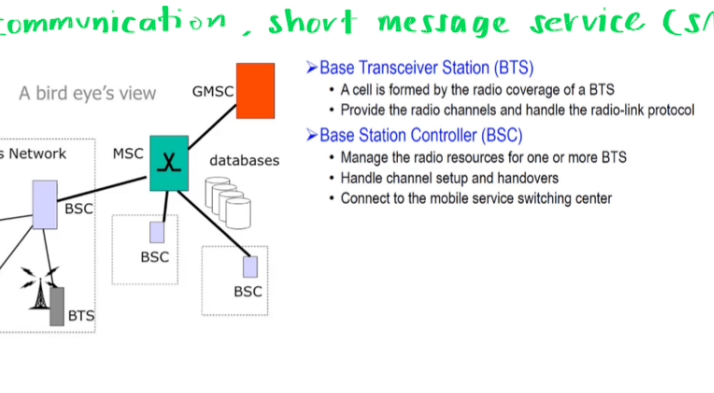


Cellular nw generations

- 1G
  - used analog signals to carry voice
- 2G
  - one standard (GSM) ; uses digital signals to carry voice
  - 2.5G used for systems that extend 2G to include some 3G features
- 3G & 3.5G
  - focused on higher speed data services (400 kbps to 2 Mbps)
  - supported web browsing & photo sharing
- 4G & 4G LTE (long term evolution)
  - higher data rate (20 Mbps)
  - focused on real-time multimedia
  - included multiple connection tech such as WiFi & Satellite
- 5G
  - very high speed (Gbps)
  - focuses on low latency applications, massive device connectivity
  - 90% reduction in network energy usage

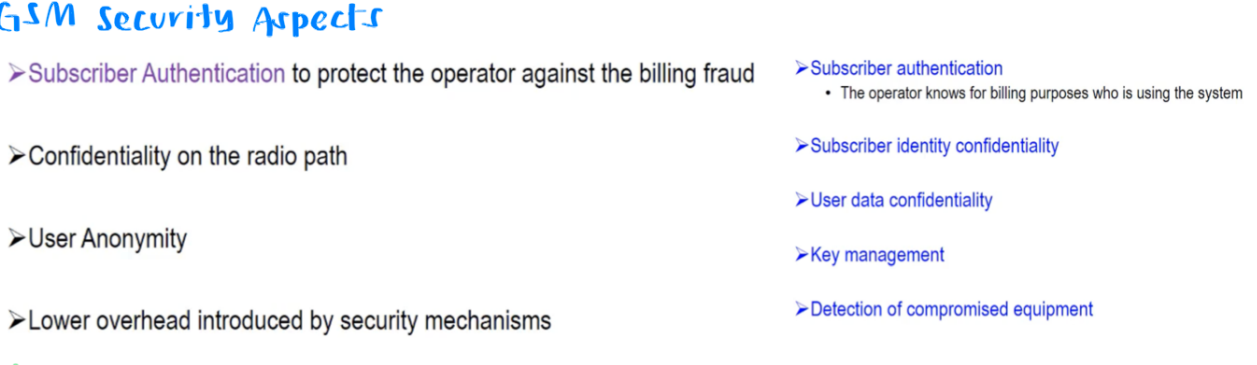
Intro to GSM (General System for Communications)

- started from 2G
- voice communication, short message service (SMS)



- Base Transceiver Station (BTS)
  - A cell is formed by the radio coverage of a BTS
  - Provide the radio channels and handle the radio-link protocol
- Base Station Controller (BSC)
  - Manage the radio resources for one or more BTS
  - Handle channel setup and handovers
  - Connect to the mobile service switching center

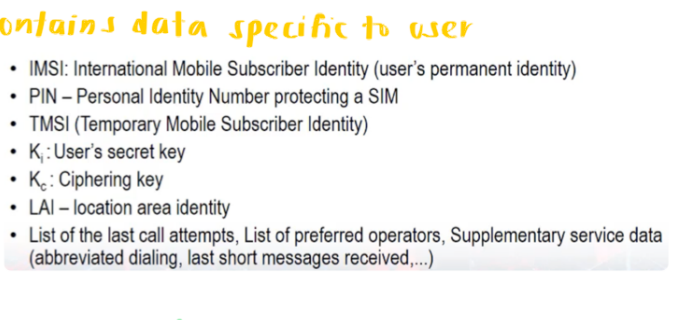
GSM Security Aspects



- Subscriber Authentication to protect the operator against the billing fraud
- Confidentiality on the radio path
- User Anonymity
- Lower overhead introduced by security mechanisms

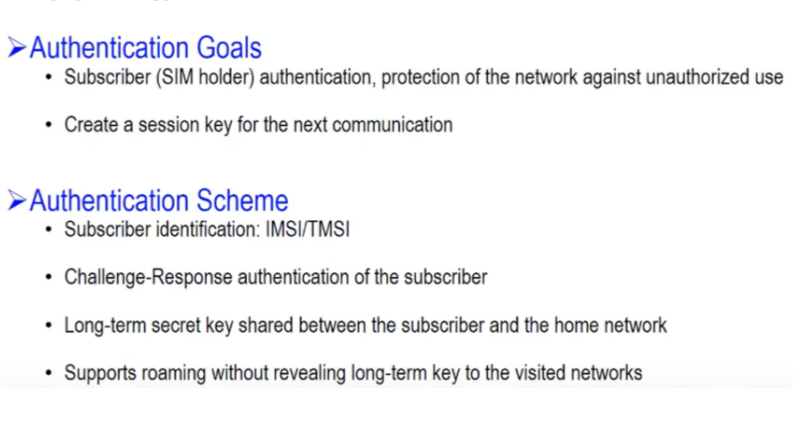
- Subscriber authentication
  - The operator knows for billing purposes who is using the system
- Subscriber identity confidentiality
- User data confidentiality
- Key management
- Detection of compromised equipment

- Subscriber Identity Module (SIM) card
  - contains data specific to user



- IMSI: International Mobile Subscriber Identity (user's permanent identity)
- PIN – Personal Identity Number protecting a SIM
- TMSI (Temporary Mobile Subscriber Identity)
- K_i : User's secret key
- K_c : Ciphering key
- LAI – location area identity
- List of the last call attempts, List of preferred operators, Supplementary service data (abbreviated dialing, last short messages received,...)

- Key management scheme
  - K_i – subscriber auth key
    - shared 128 bit key used for auth
- Authentication

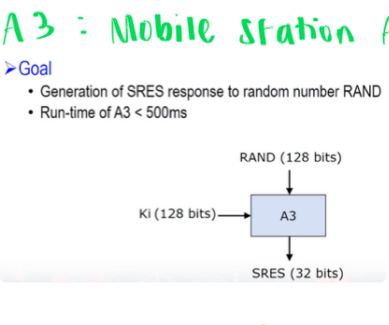


- Authentication Goals
  - Subscriber (SIM holder) authentication, protection of the network against unauthorized use
  - Create a session key for the next communication
- Authentication Scheme
  - Subscriber identification: IMSI/TMSI
  - Challenge-Response authentication of the subscriber
  - Long-term secret key shared between the subscriber and the home network
  - Supports roaming without revealing long-term key to the visited networks

Cellular Networks (Part 2)

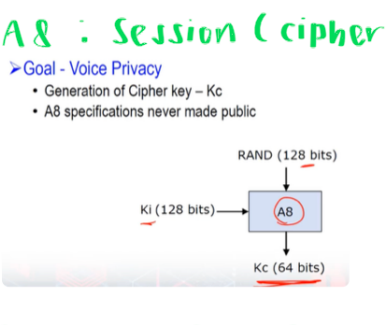
GSM Auth Algorithms

- A3 : Mobile Station Auth Algo



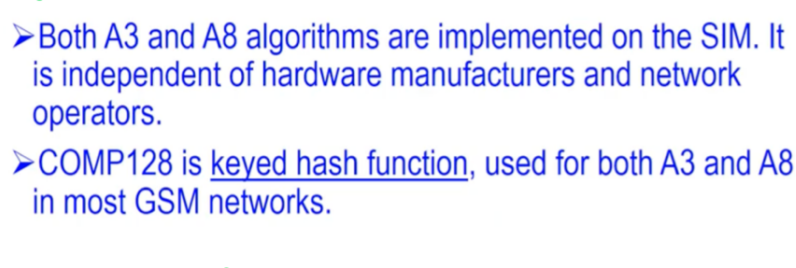
- Goal
  - Generation of SRES response to random number RAND
  - Run-time of A3 < 500ms

- A8 : Session (cipher) key generation Algo



- Goal - Voice Privacy
  - Generation of Cipher key – Kc
  - A8 specifications never made public

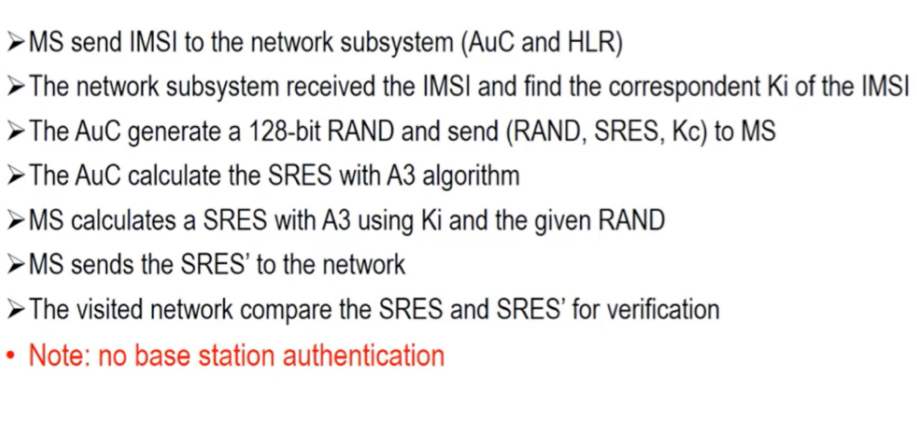
- Implementation of A3 & A8



- Both A3 and A8 algorithms are implemented on the SIM. It is independent of hardware manufacturers and network operators.
- COMP128 is keyed hash function, used for both A3 and A8 in most GSM networks.

- PRNG : Pseudo-Random Number Generator

Encryption Procedure

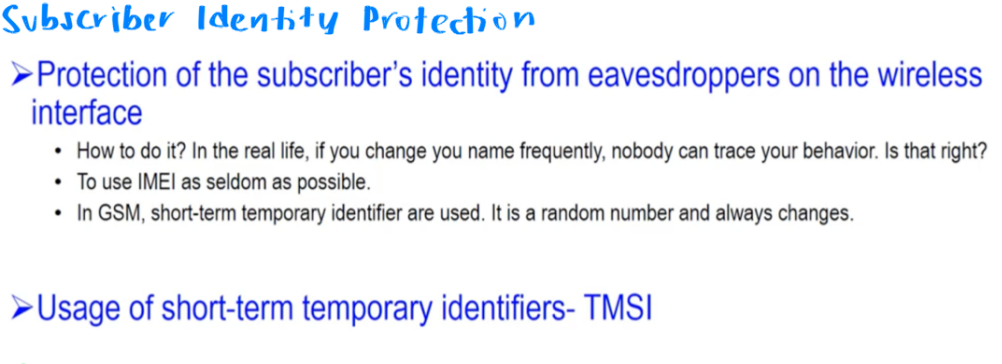


- MS send IMSI to the network subsystem (AuC and HLR)
- The network subsystem received the IMSI and find the correspondent Ki of the IMSI
- The AuC generate a 128-bit RAND and send (RAND, SRES, Kc) to MS
- The AuC calculate the SRES with A3 algorithm
- MS calculates a SRES with A3 using Ki and the given RAND
- MS sends the SRES' to the network
- The visited network compare the SRES and SRES' for verification
- Note: no base station authentication

A5

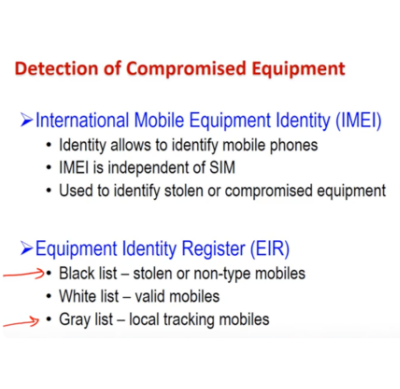
- After auth, K_c shared between subscriber & visited nw
- A5 used as OTA voice privacy algo
  - stream cipher ; implemented efficiently on hw

Subscriber Identity Protection



- Protection of the subscriber's identity from eavesdroppers on the wireless interface
  - How to do it? In the real life, if you change you name frequently, nobody can trace your behavior. Is that right?
  - To use IMEI as seldom as possible.
  - In GSM, short-term temporary identifier are used. It is a random number and always changes.
- Usage of short-term temporary identifiers- TMSI

- use TMSI instead of IMSI



Detection of Compromised Equipment

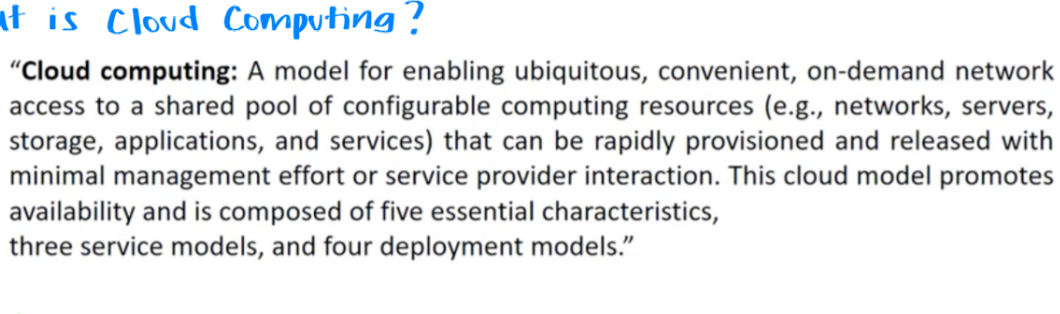
- International Mobile Equipment Identity (IMEI)
  - Identity allows to identify mobile phones
  - IMEI is independent of SIM
  - Used to identify stolen or compromised equipment
- Equipment Identity Register (EIR)
  - Black list – stolen or non-type mobiles
  - White list – valid mobiles
  - Gray list – local tracking mobiles

Attacks against GSM

- cryptanalysis attacks against
  - A3/A5/A8/COMP-128 algos
  - OTA interception using fake BTS
- DoS : jamming the signal

Cloud Security (Part 1)

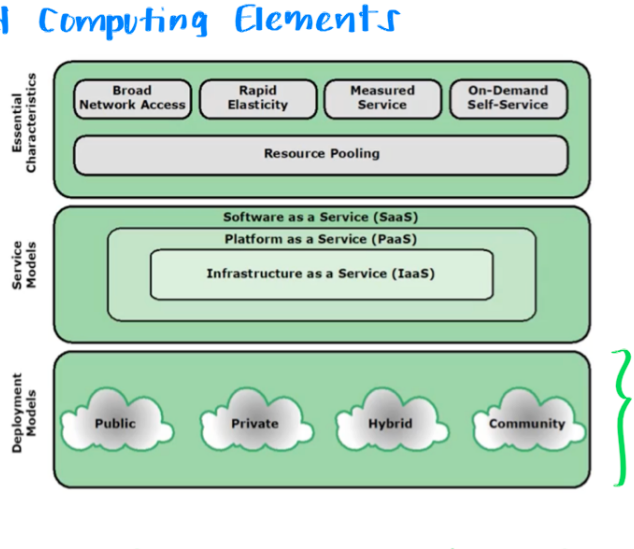
What is Cloud Computing?



"**Cloud computing:** A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models."

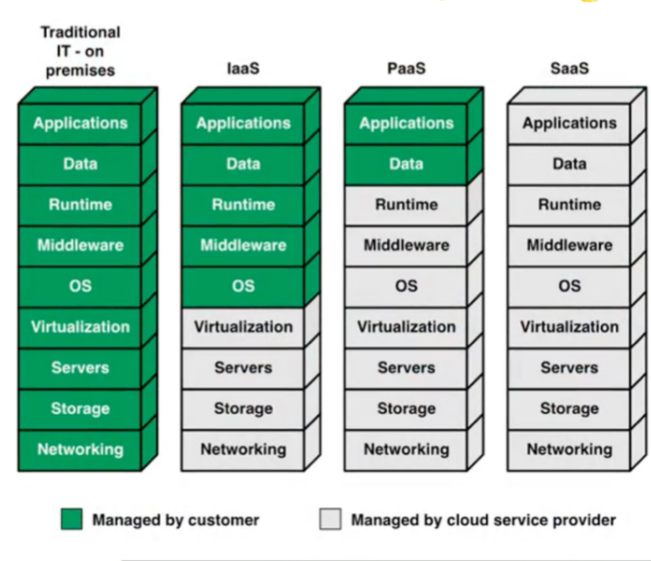
- delivery of computing services over the internet

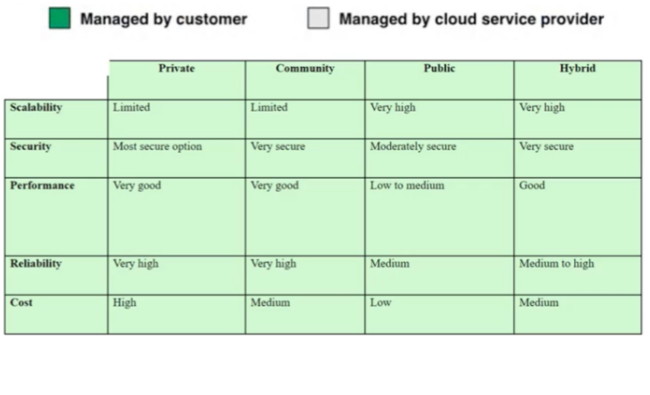
Cloud Computing Elements



- Public Cloud : Advantage : can be free / low cost
  - Disadvantage : security
- Private Cloud : Advantage : security
- Hybrid Cloud : Advantage : Combining private/public can be beneficial among other combinations
- Community Cloud : Advantage : cost

- NIST defines three service models
  - Software as a service (SaaS) WebEx, Zoom
  - Platform as a service (PaaS) Apache Stratos
  - Infrastructure as a service (IaaS) Microsoft Windows Azure

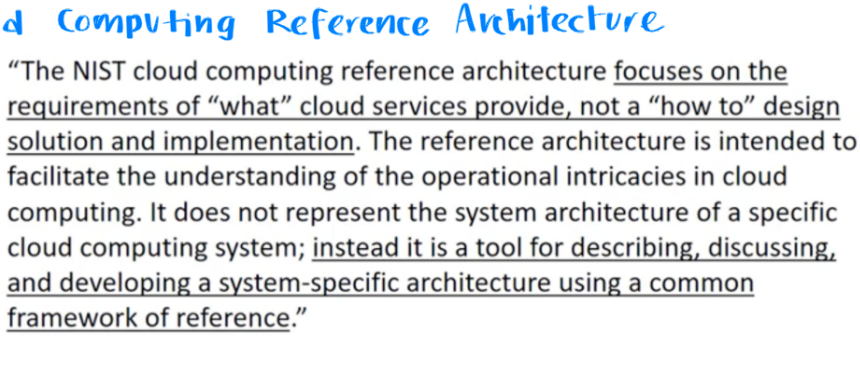




	Private	Community	Public	Hybrid
Scalability	Limited	Limited	Very high	Very high
Security	Most secure option	Very secure	Moderately secure	Very secure
Performance	Very good	Very good	Low to medium	Good
Reliability	Very high	Very high	Medium	Medium to high
Cost	High	Medium	Low	Medium

Cloud Security (Part 2)

Cloud Computing Reference Architecture



"The NIST cloud computing reference architecture focuses on the requirements of "what" cloud services provide, not a "how to" design solution and implementation. The reference architecture is intended to facilitate the understanding of the operational intricacies in cloud computing. It does not represent the system architecture of a specific cloud computing system; instead it is a tool for describing, discussing, and developing a system-specific architecture using a common framework of reference."

- NIST Cloud Computing Major Actors
  - Cloud Service Consumer (CSC) person who uses cloud services
  - Cloud Service Provider (CSP) person/organization making service avail
  - Cloud Auditor party that conducts independent assessment of services
  - Cloud Broker entity that manages services, negotiates b/w CSP & consumer
  - Cloud Carrier intermediary that provides connectivity of services

Cloud Computing Security Issues

- availability is a major concern
- business should take action against threats (internal & external)

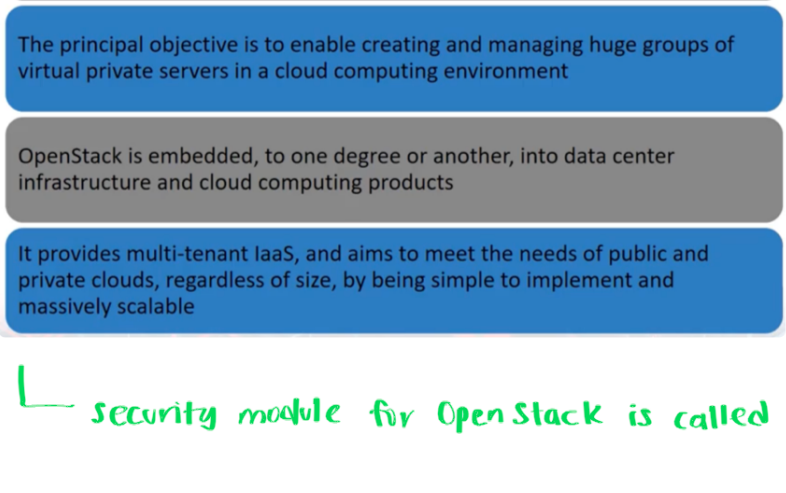
Risk & Countermeasures

- Abuse & Nefarious use of Cloud Computing
  - countermeasures : stricter registration & validation
    - inspection of customer nw traffic
- Insecure Interfaces
  - countermeasures : analyze security model of CSP
    - ensure strong auth & access controls implemented
- Malicious Insiders
  - countermeasures : specify HR requirements in legal contract
    - determine security breach notification process
- Shared Technology Isolation Issues
  - countermeasures : monitor environment for unauthorized changes/activity
    - promote strong auth & access control for admin access
- Data loss or leakage
  - countermeasures : implement strong access control
    - encrypt & protect integrity of data in transit & at rest
- Account or Service Hijacking
  - countermeasures : leverage strong 2FA techniques

Cloud Security as a Service (SecaaS)

- a segment of the SaaS offering of a CSP
- provision of security applications & services via the cloud

OpenStack



Open-source software project of the OpenStack Foundation that aims to produce an open-source cloud operating system

The principal objective is to enable creating and managing huge groups of virtual private servers in a cloud computing environment

OpenStack is embedded, to one degree or another, into data center infrastructure and cloud computing products

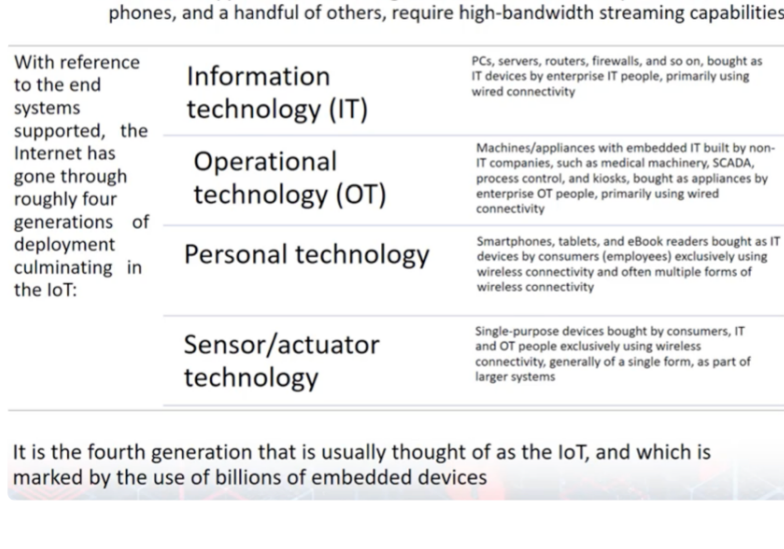
It provides multi-tenant IaaS, and aims to meet the needs of public and private clouds, regardless of size, by being simple to implement and massively scalable

- security module for OpenStack is called Keystone

IoT Security

What is IoT

- Internet of Things



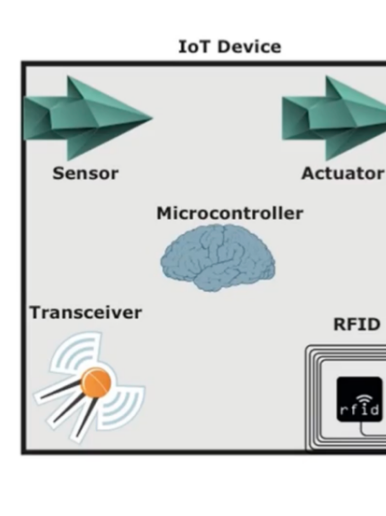
The IoT is primarily driven by deeply embedded devices

- These devices are low-bandwidth, low-repetition data capture, and low data-usage appliances that communicate with each other and provide data via user interfaces
- Embedded appliances, such as high-resolution video security cameras, video VoIP phones, and a handful of others, require high-bandwidth streaming capabilities

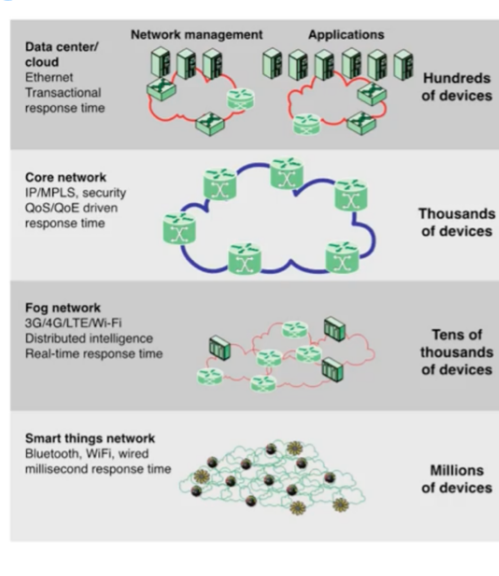
With reference to the end systems supported, the Internet has gone through roughly four generations of deployment culminating in the IoT:

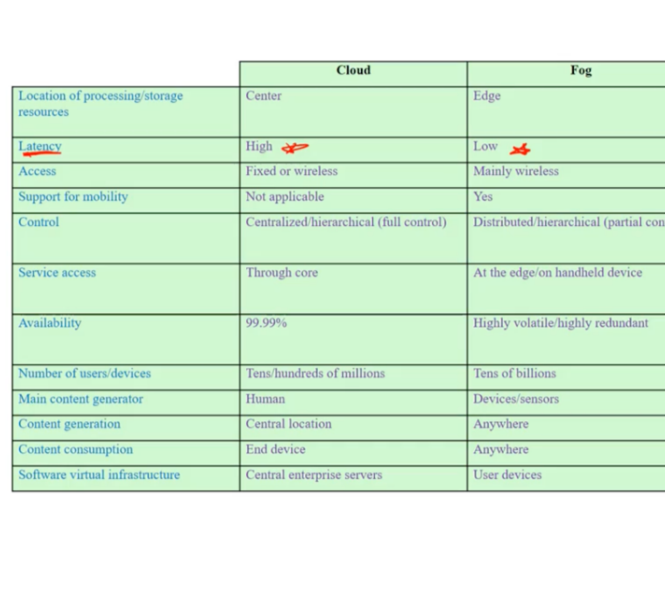
Information technology (IT)	PCs, servers, routers, firewalls, and so on, bought as IT devices by enterprise IT people, primarily using wired connectivity
Operational technology (OT)	Machines/appliances with embedded IT built by non-IT companies, such as medical machinery, SCADA, process control, and kiosks, bought as appliances by enterprise OT people, primarily using wired connectivity
Personal technology	Smartphones, tablets, and eBook readers bought as IT devices by consumers (employees) exclusively using wireless connectivity and often multiple forms of wireless connectivity
Sensor/actuator technology	Single-purpose devices bought by consumers, IT and OT people exclusively using wireless connectivity, generally of a single form, as part of larger systems

It is the fourth generation that is usually thought of as the IoT, and which is marked by the use of billions of embedded devices



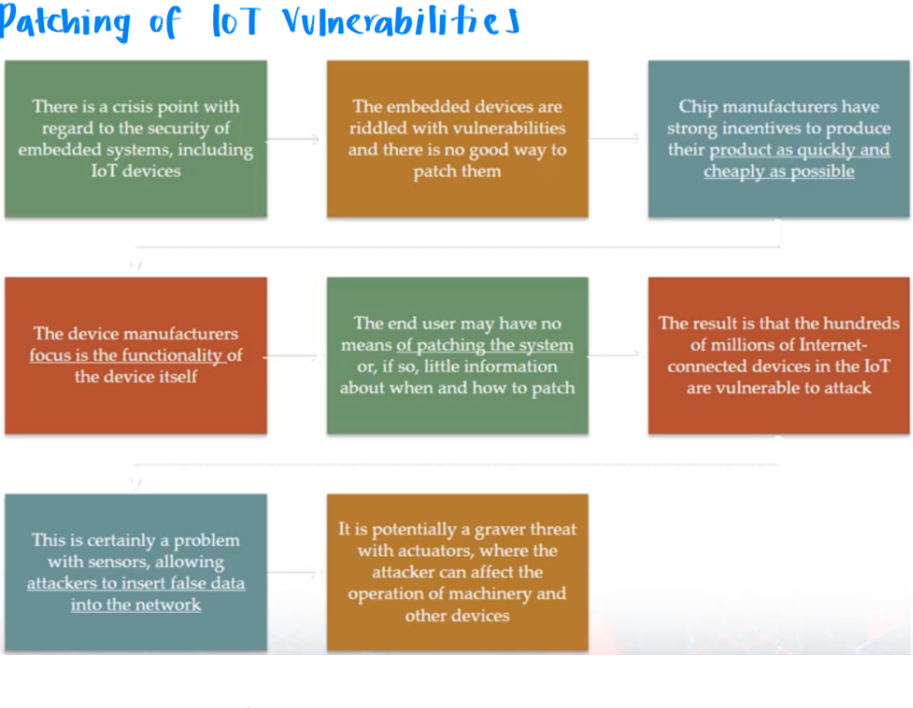
Elements of IoT Network





	Cloud	Fog
Location of processing/storage resources	Center	Edge
Latency	High	Low
Access	Fixed or wireless	Mainly wireless
Support for mobility	Not applicable	Yes
Control	Centralized/hierarchical (full control)	Distributed/hierarchical (partial control)
Service access	Through core	At the edge/on handheld device
Availability	99.99%	Highly volatile/highly redundant
Number of users/devices	Tens/hundreds of millions	Tens of billions
Main content generator	Human	Devices/sensors
Content generation	Central location	Anywhere
Content consumption	End device	Anywhere
Software virtual infrastructure	Central enterprise servers	User devices

Patching of IoT Vulnerabilities



There is a crisis point with regard to the security of embedded systems, including IoT devices

The embedded devices are riddled with vulnerabilities and there is no good way to patch them

Chip manufacturers have strong incentives to produce their product as quickly and cheaply as possible

The device manufacturers focus is the functionality of the device itself

The end user may have no means of patching the system or, if so, little information about when and how to patch

The result is that the hundreds of millions of Internet-connected devices in the IoT are vulnerable to attack

This is certainly a problem with sensors, allowing attackers to insert false data into the network

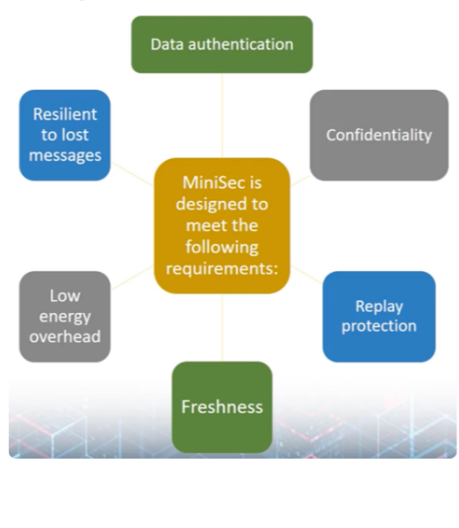
It is potentially a graver threat with actuators, where the attacker can affect the operation of machinery and other devices

IoT Security & Privacy Requirements

- requirements are defined as being the functional requirements during capturing, storing, transferring, aggregating & processing the data of things
  - requirements are :
    - communication security
    - data management security
    - service provision security
    - integration of security policies & techniques
    - mutual auth & authorization
    - security audit

MiniSec

- open source security module (part of TinyOS)
- designed to be link-level module offering high level of security
  - also keeps energy consumption low & uses very little memory
- provides confidentiality, authentication, & replay protection


Data authentication
Resilient to lost messages
Confidentiality
MiniSec is designed to meet the following requirements:
Low energy overhead
Replay protection
Freshness